

CLEARY GOTTLIB

Managing AI Risk: Legal and Governance Imperatives for the Board

January 15, 2026

The following is part of our annual publication *Selected Issues for Boards of Directors in 2026*. Explore all topics or download the PDF.



AI adoption is now mainstream: 88% of businesses use AI in at least one function, with global spending expected to exceed \$1.5 trillion in 2025 and approach \$2 trillion in 2026. As organizations race to scale AI, many have relied upon traditional vendor risk management policies to vet third-party AI vendors and tools; however, implementation of third-party AI tools presents distinctive risks that require tailored due diligence, auditing, contracting and governance. Because businesses are accountable for outputs generated by third-party AI tools and for vendors' processing of prompts and other business data, boards and management should ensure legal, IT and procurement teams apply a principled, risk-based approach to vendor management that addresses AI-specific considerations.

General Risks Inherent in AI Tools

The inherent nature of AI models presents unique risks beyond those addressed by typical vendor management:

- **Data Ingestion and Control Limitations.** Third-party AI vendors often require ingestion of substantial customer data to deliver personalized functionality. Once data is transferred to the vendor's environment, businesses face limited ability to control how that data is used, retained or incorporated into the vendor's broader operations, including potential use for model training that may benefit other customers.
- **Opacity and Lack of Transparency.** AI technology is inherently opaque, making it difficult to understand how data is processed and how or why output is produced. Vendors often incorporate third-party AI without customer awareness or may not fully disclose how AI is applied within their services; this lack of transparency creates significant data protection and confidentiality risks, as customer data may be transmitted to undisclosed third parties or used for training AI models without proper consent or contractual safeguards. The opacity of these systems may also impede a business' ability to fulfill regulatory obligations, including conducting required data protection impact assessments or bias audits.
- **Dynamic and Evolving Operation.** AI tools are not static. Instead, AI models often evolve continuously, making one-time due diligence insufficient. When AI is incorporated into existing services with existing contractual agreements, it may not trigger renewed risk management or contractual renegotiation processes, leading to gaps in coverage or insufficient protections for business data or intellectual property.
- **Inaccuracy, Bias and Hallucinations.** AI models are trained on data that may be incomplete, outdated or context-specific, creating accuracy risks. Generative AI may hallucinate, producing plausible-sounding but entirely or partially fabricated information that could mislead decision-makers or customers. Similarly, bias in training data can produce discriminatory outcomes with legal and reputational consequences in high-risk activities such as hiring decisions, credit assessments, insurance underwriting and customer profiling. These risks are amplified with third-party AI vendors, where limited transparency into proprietary training data creates significant challenges. Businesses often cannot conduct meaningful bias testing, audit algorithmic outputs for accuracy or provide explanations for automated decisions, undermining regulatory compliance and the ability to identify and remediate problematic outputs before they cause harm.

Information Security Risks

AI systems face novel attack vectors (including prompt injection, data poisoning and model inversion), where attackers manipulate inputs or infer sensitive

information from model behavior. Frequent model updates and opaque decision logic complicate security testing and auditing. These challenges are particularly acute with third-party AI vendors, where businesses often lack direct visibility into the vendor's security practices, model training environments and data handling procedures. Unlike internally developed systems, third-party AI tools often operate as "black boxes," preventing businesses from conducting comprehensive security assessments or verifying that security patches and model updates have not introduced new vulnerabilities.

The growth of agentic AI creates additional risks. Recent disclosures show that agentic AI can now independently execute complex offensive campaigns at nation-state scale, and enterprise assistants, once granted access and operational autonomy, can trigger actions that circumvent traditional enterprise controls.[1] When these agentic capabilities are embedded in third-party vendor solutions, businesses face compounded risk: they must trust not only the vendor's security controls but also their governance over autonomous agent behavior, with limited ability to monitor or constrain agent actions that occur within the vendor's infrastructure.

Privacy Risks

Third-party AI tools pose privacy risks because sensitive, personally identifiable information (PII) may be shared, processed or stored outside the business' direct control. PII triggers specific legal obligations under data protection regimes such as Europe's General Data Protection Regulation (the GDPR), the California Consumer Privacy Act (the CCPA) and China's Personal Information Protection Law (PIPL) and other privacy laws that impose strict requirements on PII processing, retention and cross-border transfers.

When PII is input into AI tools provided by a third-party vendor, it may be retained, logged or reused for model improvement, increasing risks of inadvertent disclosure, unauthorized access and secondary use. Organizations may be unable to honor data subject rights requests (e.g., rights to access, deletion and rectification) when data resides in opaque AI systems controlled by third parties or has been incorporated into training datasets. Data ingested in AI tools may also be transferred across jurisdictions, creating compliance challenges with privacy and data protection regulations.[2]

Intellectual Property Risks

Use of third-party generative AI tools poses unique IP risks:

- **Ownership Challenges.** The U.S. Patent and Copyright Offices generally deny protection to AI-generated works without significant human contribution.[3] However, to the extent proprietary rights

can be asserted in AI output, usage of vendor tools may give rise to disputes over who owns the IP in the output.

- **Open Source Software Risks.** Usage of third-party AI tools to write software code exposes businesses to open source software risks, as generative AI tools are often trained on open source software, which, if incorporated in the output, can trigger “copyleft” licensing requirements that hinder source code protection.
- **Confidentiality Risks.** Confidential or trade secret information input into a third-party AI tool can be retained, logged or reused by the vendor and incorporated into output for other users, resulting in potential loss of confidentiality or trade secret protection, as well as breach of contract claims.
- **Infringement Risks.** AI systems can generate output that infringes third-party IP, such as when prompts reference copyrighted materials, trademarks or patented inventions. Under typical AI vendor contracts, indemnification provisions are often limited or excluded entirely for AI-generated output, meaning the organization (not the vendor) bears responsibility for any liability arising from use of infringing output. This risk is compounded by the lack of transparency regarding training data, making it nearly impossible for organizations to conduct meaningful pre-use IP clearance.

Regulatory Risks

Regulatory risk associated with AI adoption is increasingly driven by the application of existing consumer protection, securities, civil rights and data protection laws to AI-enabled activities. Regulators have made clear that businesses deploying AI remain fully accountable for legal compliance, even where AI functionality is sourced from third-party vendors. Enforcement actions by the FTC and SEC demonstrate that reliance on vendor representations, without independent validation and governance, is insufficient and exposes businesses to enforcement risk.

Third-party AI tools materially amplify regulatory exposure because legal accountability remains with the deployer, while technical control, design decisions and underlying data inputs often sit with the vendor. Many AI vendors do not design products around a business’ specific compliance obligations, making it difficult to implement required transparency and consumer disclosures, explain automated decision-making outcomes, support consumer data protection rights or document how outcomes are generated. Limited audit rights, restricted access to training data and system logs and weak data provenance frequently leave businesses unable to substantiate compliance during regulatory inquiries or to remediate issues once identified.

Recent enforcement underscores these risks. The FTC's most impactful AI-related enforcement action against Rite Aid illustrates that businesses cannot outsource accountability for AI governance: the alleged failures stemmed from allegedly inadequate oversight, testing, monitoring and auditability of a third-party AI system. Similarly, SEC actions targeting AI washing reflect regulatory skepticism toward overstated AI claims where organizations lack demonstrable controls, validation or understanding of vendor-provided tools. In both contexts, regulators focused on the gap between marketing or deployment claims and the business' actual ability to govern and explain the AI system in use.

These risks are intensifying as AI-specific legislation emerges globally. In the United States, laws such as Colorado's AI Act, Texas's Responsible AI Governance Act and New York Local Law 144 impose affirmative obligations on AI deployers, including impact assessments, transparency obligations and safeguards against discriminatory outcomes, requirements that are difficult to satisfy without deep visibility into vendor systems. In the EU, the AI Act imposes stringent obligations on high-risk AI uses, with penalties of up to €35 million or 7% of global annual turnover. For boards, the key issue is structural: third-party AI can create a misalignment between regulatory responsibility and operational control, significantly increasing the likelihood of non-compliance, enforcement and reputational harm unless proactively governed.

It is worth noting, however, that despite these regulatory developments, significant political pressure exists in the U.S. to minimize regulatory burdens in favor of supporting innovation, as exemplified by President Trump's December 11, 2025, Executive Order, which escalates federal efforts to prevent state-level AI regulation in favor of a "minimally burdensome national policy framework," including through a task force empowered to challenge state laws inconsistent with federal innovation priorities.[4]

Recommendations for Board Action

Boards play a critical role in AI governance by setting strategic goals, supervising management and assessing organization-wide AI risks. Boards of companies that incur financial losses stemming from AI may face *Caremark* shareholder derivative suits alleging that directors breached their fiduciary duty of oversight with respect to AI-related risks. Given the rapid evolution of AI technology, the fragmented regulatory landscape and the significant legal and operational risks associated with third-party AI tools, boards and management should prioritize safe and compliant AI use by supporting centralized AI governing bodies subject to board-level oversight to guide implementation. Such steps may include:

- **Assessing whether AI is necessary** by evaluating whether proposed use cases genuinely require AI or whether traditional tools and existing resources can accomplish the same business objective with greater transparency and control, and properly defining

anticipated use cases to calibrate risk and tailor diligence, testing and auditing accordingly, particularly distinguishing between internal functions and external customer-facing applications;

- **Establishing and approving an AI vendor risk management framework** aligned with recognized standards (e.g., the NIST AI Risk Management Framework) that defines risk appetite and approval thresholds reflecting the business' tolerance for AI-related risks across different use cases, data sensitivity levels and regulatory environments;
- **Allocating resources for vendor diligence and monitoring**, recognizing that AI vendor assessment requires specialized expertise and ongoing oversight beyond traditional technology procurement, including budget for independent third-party auditors with AI expertise to conduct periodic reviews of vendor AI systems, data handling practices and security controls;
- **Implementing vendor transparency requirements**, including obtaining detailed model cards and technical documentation defining the AI system's category, algorithm type, learning methodology and capabilities; scrutinizing training data sources, ownership, legal authorizations and vendor practices for verifying accuracy, mitigating bias and managing model drift and confirming whether vendors use customer data to train models and requiring clear documentation of data handling practices and data reuse limitations;
- **Ensuring vendor contracts contain AI-specific protections**, including explicit restrictions on vendor use of business data for model training or improvement; clear ownership allocation for AI-generated outputs and custom models; robust audit rights permitting periodic review of AI systems, data handling practices and security controls; appropriate indemnification provisions addressing IP infringement and privacy violations and confidentiality protections with technical safeguards (such as data isolation and access controls) to prevent inadvertent exposure of proprietary information through outputs to other users;
- **Addressing AI-specific information security risks**, including vendor safeguards against novel attack vectors such as prompt injection, data poisoning and model inversion; security testing protocols that account for frequent model updates and opaque decision logic and governance controls over agentic AI capabilities to prevent autonomous actions that circumvent traditional enterprise security controls, with particular emphasis on visibility into vendor security practices, model training environments and data handling procedures; and

- **Requiring periodic reporting on high-risk AI vendors**, including updates on vendor security incidents, regulatory developments, contract negotiations and emerging risks that may require board attention or strategic adjustment.

This article was republished by Columbia Law School's *Blue Sky Blog*.

[1] For comprehensive analysis of the security implications of these incidents and recommended due diligence measures, see our November blog post available [here](#).

[2] For example, where data, including PII, is hosted or stored in certain jurisdictions, particularly the United States, organizations may face additional legal complexities arising from government access laws such as the U.S. CLOUD Act and the concerns raised in the *Schrems* decisions regarding adequacy of data protection for EU PII transferred outside the EEA.

[3] For additional information, see our article on AI Copyright Litigation elsewhere in this memorandum.

[4] For analysis of the Executive Order, see our December blog post available [here](#).

CLEARY LAWYERS INVOLVED

Daniel Ilan

New York

Melissa Faragasso

New York

Megan Medeiros

New York

VIEW OTHER PUBLICATIONS

Artificial Intelligence

Intellectual Property

Technology



© 2026 Cleary Gottlieb Steen & Hamilton LLP
Attorney Advertising. Prior results do not guarantee a similar outcome.